

Tim Farnung, Dieter Grünke, Erik Sauer, Leonhard Schneider

Projekt: StudyConnect

Lab1

Incidentanalyse

Was ist passiert

Axios Npm Version mit Hintertür wurde von Angreifern veröffentlicht.

Wie ist es passiert

Social Engineering; in einem Slack-space wurde der Maintainer zu einem MS-Teams Meeting eingeladen, der als Teams Update getarnte Trojaner wurde dann von dem Maintainer heruntergeladen.

Folgen

Mit dem Trojaner wurden die NPM Zugangsdaten des Axios-Maintainers abgegriffen und für das Veröffentlichen einer Axios Version mit Hintertür verwendet.

Betroffene SDLC-Phasen

- Operations and Maintenance

Präventive Maßnahmen:

- 2 Faktor Authentifizierung für npm Plattform mit zweitem Gerät
- Zwingendes Code Review einer zweiten Person
- Security fokusierte Codeanalyse in CI Pipeline

Unser Projekt

StudyConnect

Zweck

Erstellen und verwalten von Aufgaben und Arbeitsgruppen mit Chat

Komponenten

1. **Frontend (Benutzeroberfläche):** Eine moderne, komponentenbasierte React-Webanwendung, die den Nutzern eine intuitive, grafische Ansicht ihrer To-Dos, Fristen und aktiven Lerngruppen bietet.
2. **Backend (Geschäftslogik & API):** Eine in Python (Flask) entwickelte REST-API. Sie dient als zentraler Knotenpunkt, der die Logik für das Task-Management, die Gruppenverwaltung und die Datenverarbeitung steuert.
3. **Datenbank (Persistenz):** Eine relationale PostgreSQL-Datenbank zur strukturierten und sicheren Speicherung aller Applikationsdaten (Benutzerprofile, Aufgaben, Gruppen und Mitgliedschaften).

4. **Authentifizierung & Autorisierung (IAM):** Ein integrierter Keycloak-Server. Dieser übernimmt die sichere Registrierung, das Login-Management und die Token-basierte Zugriffsverwaltung (Sicherstellung, dass nur eingeloggte Nutzer auf die API zugreifen dürfen).

User

- **Allgemeine Nutzer (Studenten, Schüler):** Nutzen die App zur Selbstorganisation, können eigene Aufgaben anlegen, Gruppen beitreten, Aufgaben bearbeiten und im Gruppen-Chat kommunizieren.
- **Gruppen-Administratoren:** Ersteller von Lerngruppen, die erweiterte Rechte zur Moderation besitzen (z. B. Einladungslinks generieren, Mitglieder einladen, befördern oder entfernen).

Axios Incident Mapping

Ein social Engineering Angriff könnte für das Projekt StudyConnect genauso gefährlich sein. Wenn alle Beteiligten die 2FA mit einem separaten Gerät aktiviert haben, kann es evtl. etwas länger dauern bis die Angreifer sich Zugriff verschaffen.

Identified Top 5 Security Concerns

Insecure Direct Object Reference (IDOR) in Data Retrieval

- **Description:** The API relies on user-provided parameters in the URL without verifying if the authenticated requester has the permission to access that specific resource (Broken Access Control).
- **Technical Evidence:** In `api.py`, the route `@app.route("/api/tasks/user/string:user_id")` passes the `user_id` directly to the service layer. While `@keycloak_protect` ensures the user is logged in, it does not validate if the sub (Subject) claim in the JWT matches the requested `user_id`.
- **Impact:** Any authenticated student can iterate through User-IDs and retrieve the private task lists of any other student in the database.

Broken Authorization on Write Operations

- **Description:** There is a lack of ownership verification when modifying or deleting existing resources.
- **Technical Evidence:** The `update_task_service` in `services.py` processes updates based on a `task_id`. Although it validates state transitions (e.g., "todo" to "in_progress"), it fails to check if the `editor_user_id` is the owner of the task or a member of the associated group.
- **Impact:** A malicious user could send unauthorized PUT or DELETE requests to manipulate or erase tasks belonging to other study groups by simply guessing or discovering task IDs.

Mass Assignment Vulnerability

- **Description:** The application automatically maps client-side input to internal database models without filtering for protected fields.
- **Technical Evidence:** In `update_task_service`, a loop iterates over a list of fields (including `user_id` and `group_id`) and applies updates via `setattr(task, field, data[field])`.

- Impact: An attacker can "steal" a task by overriding the `user_id` field in the update request, effectively changing the owner of the resource to themselves.

Unauthorized Group Escalation (Invite Bypass)

- Description: The logical implementation of the group-join feature bypasses the intended business logic of secure invitations.
- Technical Evidence: While the Group model contains an `invite_link` field, the endpoint `/api/groups/join` calls `join_group_service` using only a `group_id`. No token or invitation secret is validated during this process.
- Impact: The privacy of study groups is compromised. Any user can join any private group by sending a POST request with the target `group_id`, gaining access to internal discussions and materials.

Injection Risks & Missing Rate Limiting

- Description: The system lacks server-side input sanitization for text fields and does not limit the frequency of API requests.
- Technical Evidence: Fields such as notes or description are stored directly in the PostgreSQL database without sanitization. Furthermore, there is no middleware to throttle requests to the `/api/users/register` or task creation endpoints.

Impact:

- Stored XSS: Malicious scripts could be injected into group notes, executing in the browsers of other group members.
- Denial of Service (DoS): An attacker could automate the creation of thousands of dummy accounts or tasks, exhausting database resources and causing system downtime.

SDLC Mapping & Future Mitigation

- Every resource access is validated against the requester's identity.
- Input validation is enforced at the API gateway level.
- Ownership checks are mandatory for all state-changing operations.